

VentureMiner AI

Compliance & Legal Matrix

Document: 09-Supplementary / 35_compliance_legal_matrix

Version: v1.0

Date: 2026-07-20

Author: VentureMiner AI Documentation Team

Status: Approved

Project: VentureMiner AI — AI Venture Intelligence Platform

Table of Contents

Document 35 — Compliance & Legal Matrix

Table of Contents

- 1. Purpose & Scope
- 2. Compliance principles
- 3. Standards & regulations
- 4. Per-standard obligations
 - 4.1 SOC 2 (Type II)
 - 4.2 ISO 27001
 - 4.3 GDPR
 - 4.4 CCPA / CPRA
 - 4.5 EU AI Act
 - 4.6 Accessibility (WCAG 2.1 AA + Section 508)
- 5. Contract templates
- 6. Sub-processors
- 7. Customer-facing documents
- 8. Internal training
- 9. Audit cadence
- 10. Non-compliance handling
- 11. EU AI Act specifics
- 12. International data transfers
- 13. Open issues
- 14. Appendix
 - 14.1 Revision history
 - 14.2 Cross-references

Document 35 — Compliance & Legal Matrix

The matrix of every regulation, standard, and contract clause that affects VentureMiner AI — and how we meet each one. The single source of truth for the legal/compliance surface.

Table of Contents

1. Purpose & Scope
2. Compliance principles
3. Standards & regulations
4. Per-standard obligations
5. Contract templates
6. Sub-processors
7. Customer-facing documents
8. Internal training
9. Audit cadence
10. Non-compliance handling
11. EU AI Act specifics
12. International data transfers
13. Open issues
14. Appendix

1. Purpose & Scope

This document is the contract for compliance and legal. It governs:

- The standards and regulations we comply with.
- The controls that satisfy each obligation.
- The contract templates we publish.
- The sub-processor list and review cadence.
- The cadence of internal and external audits.

It does not replace the Security Architecture (Document 21) or Data Governance (Document 29); it ties them together at the regulatory level.

2. Compliance principles

1. Compliance is a product feature. Built in, not bolted on.
2. Default to the strictest standard. When in doubt, we follow the strictest.
3. Documented controls. Every control has an owner and evidence.
4. Independent verification. Audits and pentests are external.

3. Standards & regulations

SOC 2 Type II	Security, availability, confidentiality	In progress	GA
ISO 27001	Information security	Planned	M18
GDPR	EU personal data	Live	Launch
CCPA / CPRA	California consumer privacy	Live	Launch
UK GDPR + DPA 2018	UK	Live	Launch
LGPD	Brazil	Live	Launch
PIPL	China	Planned (Enterprise only)	M18
EU AI Act	AI risk classification	In progress	M12
HIPAA	Healthcare PHI	Not in scope v1	—
PCI DSS	Card data	Not applicable (Stripe)	—
FedRAMP	US gov	Not in scope v1	—
TX-RAMP	Texas state	Not in scope v1	—
WCAG 2.1 AA	Accessibility	Live	Launch
Section 508	US accessibility	Live	Launch

4. Per-standard obligations

4.1 SOC 2 (Type II)

Trust service criteria: Security, Availability, Confidentiality.

CC1 — Control environment	Code of conduct, security training, governance	Doc 28
CC2 — Communication	Internal comms, customer-facing status page	Doc 25, 28
CC3 — Risk assessment	Annual risk assessment, threat model	Doc 21
CC4 — Monitoring	SIEM, log monitoring, anomaly detection	Doc 25
CC5 — Control activities	Access reviews, change management	Doc 23, 26
CC6 — Logical & physical access	RBAC, MFA, SSO, audit log	Doc 21
CC7 — System operations	Backup, monitoring, incident response	Doc 28

CC1 — Control environment	Code of conduct, security training, governance	Doc 28
CC8 — Change management	CI/CD, code review, migrations	Doc 23, 24
CC9 — Risk mitigation	Vendor reviews, business continuity	Doc 21, 28
A1 — Availability	SLOs, DR	Doc 25, 28
C1 — Confidentiality	Encryption, access controls	Doc 21

Audit cadence: annual Type II; observation period starts at launch.

4.2 ISO 27001

- Statement of Applicability (SoA): every Annex A control evaluated.
- Risk register: maintained quarterly.
- ISMS: owned by Security Lead.
- Surveillance audits: annual after certification.

4.3 GDPR

- DPO: appointed (or DPO-as-a-service).
- Records of processing activities (ROPA): maintained.
- Data subject rights: access, rectification, erasure, portability, objection.
- Breach notification: < 72h to supervisory authority.
- DPAs with all sub-processors.

4.4 CCPA / CPRA

- Privacy notice lists data categories and purposes.
- Do-not-sell link in footer.
- Consumer rights honored within 45 days.

4.5 EU AI Act

Risk classification: TBD (likely "limited risk" with transparency obligations).

Obligations (provisional):

- Transparency: users must know they're interacting with an AI.
- Documentation: technical documentation of high-risk systems.
- Human oversight: humans can override AI decisions.
- Bias monitoring: dataset and model bias assessment.
- Logging: traceability of AI decisions.

- Verifier agent (Document 09 §16) — human-overridable.
- Drift and bias monitoring (Document 18).
- Append-only audit log of AI calls.

4.6 Accessibility (WCAG 2.1 AA + Section 508)

- Per Document 04 §17.
- Annual third-party audit.

5. Contract templates

Terms of Service	All users	v2.1 (current)
Privacy Policy	All users	v2.1
Master Service Agreement (MSA)	Enterprise	v1.4
Data Processing Addendum (DPA)	All paid; mandatory Enterprise	v1.3
Business Associate Agreement (BAA)	Healthcare (not v1)	v1.0
Acceptable Use Policy (AUP)	All users	v1.2
Service Level Agreement (SLA)	Team+, mandatory Enterprise	v1.0
Sub-processor list	Public	live, updated within 30d of change

Owners: General Counsel + Privacy Lead. Review cadence: annually; or upon regulatory change.

6. Sub-processors

The public sub-processor list is at legal.ventureminer.ai/sub-processors. New sub-processors are announced 30 days before activation.

Auth0	Authentication	US, EU	✓
Anthropic	LLM	US	✓
OpenAI	LLM fallback	US	✓
Stripe	Billing	US, EU	✓
Postmark	Email	US	✓
AWS	Infrastructure	Multi	✓
Datadog	Observability	US, EU	✓
Cloudflare	CDN	Global	✓
HubSpot	Marketing	US, EU	✓
Sanity	CMS	US, EU	✓

Auth0	Authentication	US, EU	✓
Intercom	Support chat	US, EU	✓
Zendesk	Support	US, EU	✓

7. Customer-facing documents

- Privacy policy — public, plain-language summary.
- Cookie policy — banner + page.
- DPA — self-serve download.
- Sub-processor list — public.
- SOC 2 report — under NDA (Enterprise).
- Penetration test summary — under NDA (Enterprise).
- Security questionnaire — Standard SIG, CAIQ pre-filled.
- Insurance certificates — under NDA.

8. Internal training

- Onboarding: security + privacy training in week 1.
- Annual refresher: all employees.
- Phishing simulation: quarterly.
- Secure code training: engineers; quarterly.
- AI ethics training: all AI plane engineers + PMs; annually.

9. Audit cadence

SOC 2 Type II	Annual	Security Lead
ISO 27001	Annual after cert	Security Lead
Penetration test	Annual + on major release	Security Lead
Privacy impact assessment (PIA)	Per new feature	Privacy Lead
DPIA	Per high-risk processing	Privacy Lead + DPO
Sub-processor review	Annual	Security Lead
Accessibility audit	Annual	Design Lead
Internal compliance review	Quarterly	Compliance Lead

10. Non-compliance handling

Internal incident	Page on-call; assess breach notification; remediate
Audit finding	Open ticket; assign owner; close within 30 days (high) or 90 days (low)
Customer complaint	Engage Legal + Support; respond within 5 business days
Regulatory inquiry	Engage Legal; respond within regulator's deadline
Public disclosure	Engage Comms + Legal; coordinate with status page

11. EU AI Act specifics

- Transparency: users know they're interacting with AI (badge in UI).
- Documentation: every agent has a contract.yaml (Document 09).
- Logging: every AI call is logged (Document 18).
- Human oversight: every output can be overridden (Document 09 §13, §17).
- Bias monitoring: monthly eval on golden sets (Document 18 §3).

12. International data transfers

- EU ↔ US: Standard Contractual Clauses (SCCs).
- UK ↔ US: UK Addendum to SCCs.
- CH ↔ EU: equivalent protections.
- APAC: country-specific mechanisms (e.g. APEC CBPR for some flows).
- Data residency enforced at storage layer (Document 21 §7).

13. Open issues

- OI-01: EU AI Act final risk classification — pending legal review (Q4 2026).
- OI-02: PIPL readiness for China Enterprise — pending product decision.
- OI-03: Sub-processor regionalization for APAC — pending.
- OI-04: BAA for healthcare — out of scope v1; track in v2 roadmap.

14. Appendix

14.1 Revision history

v0.5	2026-07-20	Doc Team	All sections drafted
v1.0	2026-07-20	Doc Team	First approved version

14.2 Cross-references

- Security Architecture: Document 21.
- Data Governance: Document 29.
- Pricing: Document 31 (DPA / sub-processors).
- Operations: Document 28.

End of Document 35 — Compliance & Legal Matrix. The matrix is the source of truth; any non-compliance is a ticket, not a vibe.